

Отчёт по индивидуальному проекту № 4

Основы информационной безопасности

Луангсуваннавонг Сайпхачан, НКАбд-01-24

Содержание

1	Цель работы	5
2	Задание	6
3	Теоретическое введение	7
4	Выполнение лабораторной работы	8
5	Выводы	12

Список иллюстраций

4.1	Запуск сервера Apache	8
4.2	Изменение системы безопасности DVWA	8
4.3	Запуск Nikto с использованием URL-адреса	9
4.4	Запуск Nikto с использованием адреса хоста и порта	9

Список таблиц

1 Цель работы

Научиться использованию сканера безопасности веб-сервера nitko для тестирования веб-приложений

2 Задание

Использование nikto

3 Теоретическое введение

nikto — базовый сканер безопасности веб-сервера. Он сканирует и обнаруживает уязвимости в веб-приложениях, обычно вызванные неправильной конфигурацией на самом сервере, файлами, установленными по умолчанию, и небезопасными файлами, а также устаревшими серверными приложениями.

4 Выполнение лабораторной работы

Во-первых, я запускаю сервер Apache2, который создал ранее, так как для работы с nikto нам нужно веб-приложение для сканирования, а именно DVWA.(рис. 4.1)

```
(sayprachanh@sayprachanh)-[/var/www/html/DVWA]
$ sudo systemctl start mysql
(sayprachanh@sayprachanh)-[/var/www/html/DVWA]
$ sudo systemctl start apache2
```

Рисунок 4.1: Запуск сервера Apache

Затем я захожу в DVWA и меняю уровень безопасности на «low» (необязательно, потому что на низком уровне безопасности убираются все фильтрация ввода и средства контроля безопасности, что позволяет nikto обнаружить максимальное количество уязвимостей).(рис. 4.2)

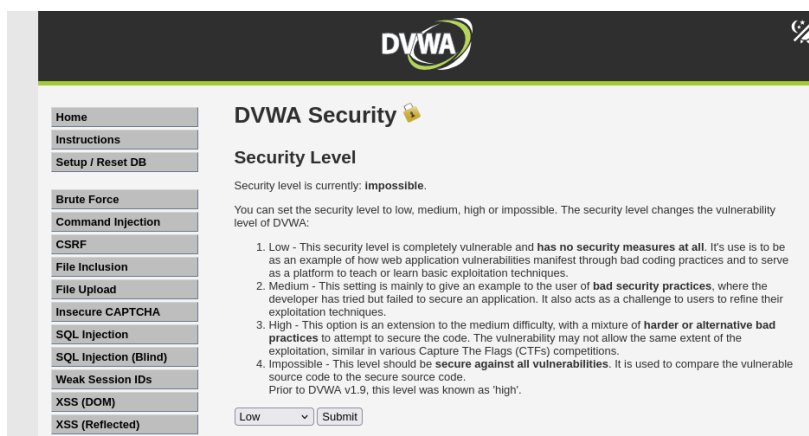


Рисунок 4.2: Изменение системы безопасности DVWA

Я запускаю `nikto`, указав URL-ссылку на наш локальный хост с DVWA. В результате он отображает информацию о различных уязвимостях приложения.(рис. 4.3)

```
(sayprachanh@sayprachanh) ~ [~/var/www/html/DVWA]
$ nikto -h http://127.0.0.1/DVWA
- Nikto v2.5.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 80
+ Start Time: 2026-04-02 14:01:34 (GMT3)

+ Server: Apache/2.4.65 (Debian)
+ /DVWA/: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /DVWA/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Root page /DVWA redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ OPTIONS: Allowed HTTP Methods: OPTIONS, HEAD, GET, POST.
+ /DVWA//etc/hosts: The server install allows reading of any system file by adding an extra '/' to the URL.
+ /DVWA/config/: Directory indexing found.
+ /DVWA/config/: Configuration information may be available remotely.
+ /DVWA/tests/: Directory indexing found.
+ /DVWA/tests/: This might be interesting.
+ /DVWA/database/: Directory indexing found.
+ /DVWA/database/: Database directory found.
+ /DVWA/docs/: Directory indexing found.
+ /DVWA/login.php: Admin login page/section found.
+ /DVWA/.git/index: Git index file may contain directory listing information.
+ /DVWA/.git/HEAD: Git HEAD file found. Full repo details may be present.
+ /DVWA/.git/config: Git config file found. Infos about repo details may be present.
+ /DVWA/.gitignore: .gitignore file found. It is possible to grasp the directory structure.
+ /DVWA/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/assets/mobirise/css/meta.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/login.cgi?cli=aa%20aa%27cat%20/etc/hosts: Some D-Link router remote command execution.
+ /DVWA/shell?cat=/etc/hosts: A backdoor was identified.
+ /DVWA/.dockerignore: .dockerignore file found. It may be possible to grasp the directory structure and learn more about the site.
+ 8074 requests: 0 error(s) and 26 item(s) reported on remote host
+ End Time: 2026-04-02 14:01:57 (GMT3) (23 seconds)
```

Рисунок 4.3: Запуск Nikto с использованием URL-адреса

Затем я снова пытаюсь запустить `nikto`, но на этот раз указываю порт, добавив `-p 80`, а также меняю хост: вместо URL я использую адрес `localhost`. Результат отличается.(рис. 4.4)

```
(sayprachanh@sayprachanh) ~ [~/var/www/html/DVWA]
$ nikto -h http://127.0.0.1/DVWA -p 80
- Nikto v2.5.0

ERROR: The -port option cannot be used with a full URI

(sayprachanh@sayprachanh) ~ [~/var/www/html/DVWA] [Level]
$ nikto -h 127.0.0.1 -p 80
- Nikto v2.5.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 80
+ Start Time: 2026-04-02 14:03:33 (GMT3)

+ Server: Apache/2.4.65 (Debian)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories Found (use '-C all' to force check all possible dirs)
+ /: Server may leak inodes via ETags, header found with file //, inode: 29cf, size: 64b8b7f0eb186, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: OPTIONS, HEAD, GET, POST.
+ //etc/hosts: The server install allows reading of any system file by adding an extra '/' to the URL.
+ /server-status: This reveals Apache information. Comment out appropriate line in the Apache conf file or restrict access to allowed sources. See: OSVDB-561
+ /wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /assets/mobirise/css/meta.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /login.cgi?cli=aa%20aa%27cat%20/etc/hosts: Some D-Link router remote command execution.
+ /shell?cat=/etc/hosts: A backdoor was identified.
+ 8074 requests: 0 error(s) and 15 item(s) reported on remote host
+ End Time: 2026-04-02 14:03:55 (GMT3) (22 seconds)
```

Рисунок 4.4: Запуск Nikto с использованием адреса хоста и порта

Результат после сканирования: оба сканирования — через URL и через адрес порта — дают разные результаты, но оба показывают различные уязвимости приложения, которые включают множество «бэкдоров» (backdoor), позволяющих удаленно управлять веб-приложением или получать несанкционированный доступ к данным.

Результат сканирования:

Сервер: Apache/2.4.65 (Debian)

- DVWA:/ Отсутствует заголовок X-Frame-Options для защиты от кликджекинга. См.: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options>
- DVWA:/ Не установлен заголовок X-Content-Type-Options. Это может позволить пользовательскому агенту интерпретировать содержимое сайта иначе, чем указано в MIME-типе. См.: <https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/>
- Корневая страница /DVWA перенаправляет на: login.php
- CGI-директории не найдены (используйте „-C all“ для принудительной проверки всех возможных директорий)
- OPTIONS: Разрешённые HTTP-методы: OPTIONS, HEAD, GET, POST.
- DVWA:/etc/hosts: Установка сервера позволяет читать любые системные файлы, добавляя лишний „/“ в URL.
- DVWA/config/: Найдено индексирование директории.
- DVWA/config/: Конфигурационная информация может быть доступна удалённо.
- DVWA/tests/: Найдено индексирование директории.
- DVWA/tests/: Это может быть интересно.
- DVWA/database/: Найдено индексирование директории.
- DVWA/database/: Найдена директория с базой данных.
- DVWA/docs/: Найдено индексирование директории.

- DVWA/login.php: Найдена страница входа администратора / раздел входа.
- DVWA/.git/index: Git-файл index может содержать информацию о листинге директорий.
- DVWA/.git/HEAD: Найден Git-файл HEAD. Может присутствовать полная информация о репозитории.
- DVWA/.git/config: Найден Git-файл config. Может содержать информацию о деталях репозитория.
- DVWA/.gitignore: Найден файл .gitignore. Можно понять структуру директорий.
- DVWA/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: Найден PHP-бэкдор — файловый менеджер.
- DVWA/wp-admin/uploads/Requests/Utility/content-post.php?filesrc=/etc/hosts: Найден PHP-бэкдор — файловый менеджер.
- DVWA/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: Найден PHP-бэкдор — файловый менеджер.
- DVWA/wp-includes/js/tinymce/themes/modern/Meuhey.php?filesrc=/etc/hosts: Найден PHP-бэкдор — файловый менеджер.
- DVWA/wp-includes/js/tinymce/themes/modern/Meuhey.php?filesrc=/etc/hosts: Найден PHP-бэкдор — файловый менеджер.
- DVWA/assets/mobirise/css/meta.php?filesrc=/etc/hosts: Найден PHP-бэкдор — файловый менеджер.
- DVVAA/login.cgi?cli=aa%20aa%27cat%20/etc/hosts: Обнаружено удалённое выполнение команд на некоторых маршрутизаторах D-Link.
- DVWA/shell?cat=/etc/hosts: Идентифицирован бэкдор.
- DVWA/.dockerignore: Найден файл .dockerignore. Возможно, удастся понять структуру директорий и узнать больше о сайте.

5 Выводы

Я научился использовать сканер безопасности веб-сервера nitko для тестирования веб-приложений